

HIPAA Compliance Audit

Static Scan + Guided Interview Skill for Claude Code

Global Software Consulting · v0.1.0 · 2026-06-23
github.com/Global-Software-Consulting/hipaa-audit-skill

Agenda

1. Why HIPAA matters — the cost of getting it wrong
2. HIPAA in 30 seconds — the three rules
3. What counts as PHI — the 18 identifiers
4. What we built — overview
5. Three-phase architecture
6. Phase 1 — auto-scan (code, infra, deps)
7. Phase 2 — guided off-code interview
8. Phase 3 — merged scored report
9. Output samples — HTML / MD / JSON
10. Verdict + scoring model
11. Honest coverage + confidence levels
12. Use cases for our team
13. Install & run
14. Roadmap — what's next
15. Q&A

Why HIPAA matters

The exposure

- US federal law protecting **Protected Health Information (PHI)**
- Applies to every vendor touching health data (we're a **Business Associate**)
- No signed BAA + PHI flow = automatic violation
- State AGs, class actions, OCR all enforce independently

Cost of getting it wrong

- Fines \$137–\$2M per violation category, per year
- Criminal penalties up to 10 years prison for wilful neglect
- Mandatory breach disclosure (60 days)
- Lost healthcare deals — no clinical partner without proof

Recent enforcement (2022–2025)

- Multiple hospitals settled lawsuits over Meta Pixel on patient portals
- OCR issued tracking technology bulletin (Dec 2024) — GA4 on clinical pages = breach
- \$1.3M settlement (2024) — Doctors Management Services / ransomware
- \$2.5M settlement (2025) — health plan / encryption gap

Source: HHS OCR enforcement releases

HIPAA in 30 seconds — the three rules

Privacy Rule

Who can see PHI

- Minimum necessary access
- Patient rights: access, amend, accounting of disclosures
- Written authorization outside TPO

Security Rule

How to protect ePHI

- **Administrative** — training, risk analysis, BAAs
- **Physical** — facility, workstation, device disposal
- **Technical** — encryption, audit logs, access controls

Breach Notification

What to do when you leak

- 60-day notification clock
- ≥500 affected = HHS + media
- Burden of proof on YOU

Roles to remember

ROLE	MEANING	EXAMPLE
Covered Entity (CE)	Provider, insurer, clearinghouse	Hospital, BlueCross
Business Associate (BA)	Vendor handling PHI for a CE	Our SaaS, AWS, Stripe
Subcontractor	BA's downstream vendor	Sentry, Datadog

What counts as PHI — Safe Harbor 18 identifiers

Strip ALL 18 + health context → no longer PHI → de-identified data, far less regulation. 45 CFR § 164.514(b)(2)

1. Names
2. Geographic info smaller than state (street, city, ZIP)
3. Dates except year (DOB, admit, discharge, death)
4. Phone numbers
5. Fax numbers
6. Email addresses
7. SSN
8. Medical record numbers (MRN)
9. Health plan / insurance numbers
10. Account numbers
11. License / certificate numbers
12. Vehicle IDs (plate, VIN)
13. Device serial numbers
14. Web URLs identifying individuals
15. IP addresses
16. Biometric IDs (fingerprint, voice, retina)
17. Full-face photographs
18. Any other unique identifying code

Where this bites in our code

If any of these 18 + health info ends up in **logs, URLs, push notifications, analytics, error trackers, or screenshots** — we have a disclosure event. Phase 1 of the skill scans for exactly these patterns.

What we built

A Claude Code skill that audits any project in 3 phases

Overview

The problem

- HIPAA audits cost \$50k–\$300k and take 3–9 months
- Engineers don't know what auditors actually check
- By the time auditor finds gaps, fixing them blocks launch
- Healthcare clients ask for HIPAA story up-front in pre-sales

What our skill does

- Runs a deterministic scanner over code + infra + deps in < 30 sec
- Then drives a structured 45-question interview for policy + process gaps
- Produces a scored verdict + remediation roadmap
- Generates HTML dashboard inside the audited project

24

BASELINE RULES

45+

INTERVIEW
QUESTIONS

12

CATEGORIES

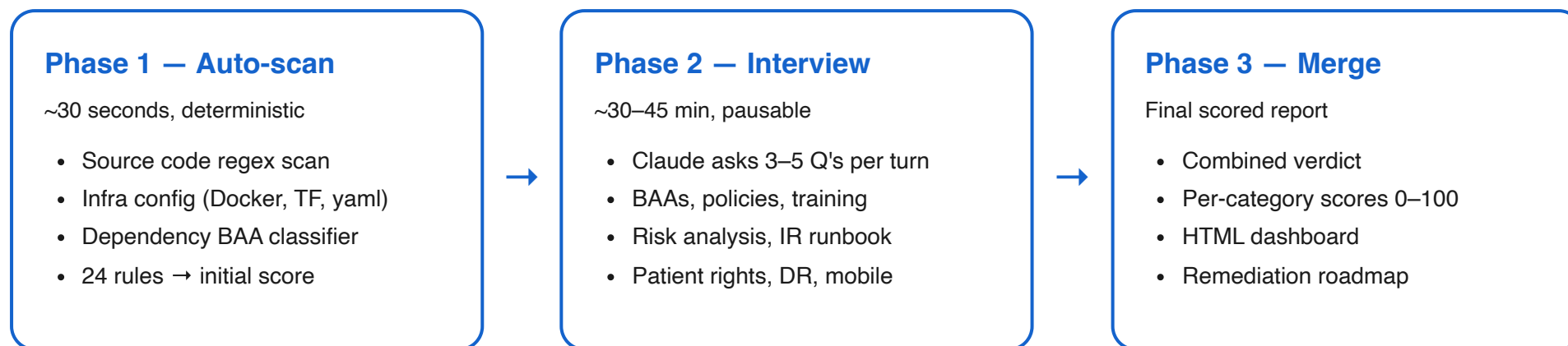
0

PYTHON DEPS

62%

HIPAA COVERAGE

Three-phase architecture



Why three phases?

Code scan alone catches ~12% of HIPAA obligations. The other ~50% lives in policies, BAAs, training records, runtime evidence — invisible to a regex. Interview captures it via structured Q&A. Combined coverage: ~62%.

Phase 1 — what the auto-scan catches

Source code patterns

- PHI identifier patterns inside log statements (SSN, email, phone, MRN, DOB)
- PHI in URL construction
- Hardcoded API keys / tokens / passwords
- Plaintext `http://` URLs
- Disabled TLS verification (`verify=False` , `rejectUnauthorized: false`)
- Wildcard CORS (`*`)
- Missing session timeout / auto-logout
- Audit log scaffolding present?

Infrastructure config

- DB encryption at rest (RDS, MongoDB, Firestore)
- S3 / object storage default encryption
- Backup encryption
- TLS minimum version (1.2+)
- HSTS header configuration
- Public bucket misconfiguration
- Log retention policy hints
- `.env` file committed to repo

Dependency classification

- Vendors that **refuse BAA** (GA4, Meta Pixel, Mailchimp)
- Vendors needing **Enterprise tier** for BAA (Sentry, Datadog, Vercel)
- Vendors with **signable BAA** (AWS, Stripe, Twilio)

Phase 2 — the off-code interview

Claude reads `docs/interview.json`, walks you through 12 sections, asks 3–5 questions per turn, saves answers after each batch. Resumable.

1. BAAs

- CE BAAs
- Subprocessor BAAs
- Review cadence

2. Risk Analysis

- NIST 800-30 doc
- Last review date
- Mitigation plan

3. Workforce

- Annual training
- Sanction policy
- Privacy/Security Officers
- Termination procedure

4. Access Reviews

- Review cadence
- MFA enforced
- No shared accounts

5. Audit Logs

- PHI read logged
- Immutable storage
- 6yr retention
- Review cadence

6. Encryption (runtime)

- Cloud-console verified
- Backup restore tested
- KMS key mgmt
- External TLS scanned

7. Incident Response

- Runbook exists
- Tabletop tested
- Breach log kept
- Notification template

8. Physical

- Facility policy
- Device disposal (NIST 800-88)
- Workstation security

9. Disaster Recovery

- DR plan w/ RTO/RPO
- Last DR test
- Backup offsite

10. De-identification

- Prod-only PHI
- De-id method
- Re-id test attempted

11. Patient Rights

- NPP published
- Access requests
- Amendments
- Accounting of disclosures
- Minimum necessary

12. Mobile-specific

- Cert pinning
- Biometric lock
- Screenshot block
- No PHI in push
- Keychain tokens

Phase 3 — merge & final report

What happens

- Interview answers converted to findings
- Yes → pass, No / partial → fail, Unknown → manual
- Date answers older than 12 months → fail (stale)
- All findings re-scored together
- Verdict + per-category scores recalculated
- HTML + MD + JSON re-rendered
- Reports auto-copied into project root

What Claude does next

- Walks you through top 5 MUST-fix items
- Proposes owners + deadlines
- Offers to draft skeleton policy docs you're missing
- Offers to create Jira/Linear tickets for each remediation
- Schedules a follow-up audit after fixes

Real test on sms-frontend (internal project)

STAGE	RULES	SCORE	VERDICT
Phase 1 only	24	68/100	Not Compliant (4 false positives identified)
Phase 1 + 2	47	~50/100 expected	Reveals real process gaps (risk analysis, IR runbook, BAA chain)

Output — what the team sees

HTML dashboard (auto-opens in browser)

- Verdict badge + score gauge (color-coded)
- KPI grid: rules total, MUST/SHOULD fails, manual verify, passing, interview gaps
- Category bars (12 categories, 0–100 each)
- Severity distribution chart
- Vendor BAA risk table
- Filterable findings table (status / severity / code-vs-interview)
- Dark-mode aware
- Self-contained, no JS dependencies

Markdown report (audit.md)

- Executive summary with verdict + score
- Category bar chart in ASCII
- Severity summary table
- Top failing categories
- MUST-fix detail with evidence + fix hint + citation
- Remediation roadmap: Week 1 / Sprint 1 / Manual

JSON (audit.json)

- Machine-readable for CI gates
- Diffable across audits
- Powers HTML + MD renderers

File locations: /tmp/hipaa-audit-<ts>/{facts,audit,audit_final}.{json,md,html} + <project>/hipaa-audit-report.{html,md}

Verdict + scoring model

Severity weighting

SEVERITY	WEIGHT	MEANING
MUST	3.0	Required safeguard or known PHI leak path. Any failure = NOT Compliant.
SHOULD	1.5	Addressable safeguard or strong best practice.
NICE	0.5	Defense-in-depth, audit-readiness.

Category score formula

```
score = ((sum of weights for "pass") + 0.5 × (sum of weights for "manual"))
```

Verdict thresholds

VERDICT	CONDITION
Not Compliant	Any must failed OR overall < 60
Partially Compliant	No must failed AND overall 60–84
Compliant	No must failed AND overall ≥ 85 AND no critical category < 70

Critical categories: encryption-at-rest, encryption-in-transit, access-control, audit-logging, phi-in-logs, secrets-mgmt.

Honest coverage & confidence

We don't oversell. CTO-level numbers:

HIPAA BUCKET	% OF TOTAL HIPAA	CODE-ONLY	+ INTERVIEW
Technical safeguards	~25%	35%	55%
Administrative (policy/training/BAA)	~40%	0%	70%
Physical safeguards	~10%	0%	60%
Privacy Rule (patient rights)	~10%	0%	70%
Breach notification process	~10%	0%	75%
Documentation / retention	~5%	5%	70%
WEIGHTED TOTAL	100%	~12%	

Confidence by goal

GOAL	CONFIDENCE
Find obvious technical mistakes before they ship	90%
Drive team conversations about HIPAA gaps	85%
Pre-audit gap assessment	75%
Convince clinical partner you have HIPAA story	75%
Replace a HIPAA auditor	0%

Use cases for our team

1. Pre-sales / RFP response

Healthcare client asks: "Are you HIPAA ready?" Run the skill on the candidate project, share the HTML dashboard. Demonstrates we have a process, not just slides.

2. CI gate

Wire Phase 1 into GitHub Actions. Fail build if a MUST rule regresses. Catches accidental hardcoded keys, removed encryption, added blocked vendor.

3. Pre-launch gap assessment

Before clinical go-live, run all 3 phases. Triage findings. Fix critical items in-house, pay auditor only after we're confident.

4. Engineer onboarding

New devs on healthcare projects read the skill docs (HIPAA_RULES_SIMPLE.md, 18_IDENTIFIERS.md, BAA_VENDORS.md). Faster ramp than "read 200-page compliance handbook."

5. Vendor evaluation

Before adding a new SaaS dependency, check BAA_VENDORS.md. Saves cycles arguing whether vendor is acceptable.

6. Quarterly self-audit

Re-run on every active healthcare project quarterly. Diff against previous audit. Track which rules regressed and which improved.

Install & run

One-time install (per developer)

```
git clone git@github.com:Global-Software-Consulting/hipaa-audit-skill.git ~/hipaa-audit-skill
bash ~/hipaa-audit-skill/install.sh
```

Creates symlink at `~/.claude/skills/hipaa-audit` . Restart Claude Code. Done.

Use it

In Claude Code, type any of:

```
/hipaa-audit /path/to/project
hipaa audit /path/to/project
is /path/to/project hipaa compliant?
phi leak check on /path/to/project
```

Or run scanner directly (no Claude)

```
bash ~/hipaa-audit-skill/skills/hipaa-audit/scripts/run_audit.sh /path/to/project

# Output dropped here:
# /tmp/hipaa-audit-
```

Uninstall

```
bash ~/hipaa-audit-skill/uninstall.sh
```


Roadmap — what's next

P0 — kill false positives (next sprint)

- `.gitignore`-aware env scan (don't flag `.env.local` if already ignored)
- Allowlist XML namespaces (`www.w3.org` , `schema.org` , `ogp.me`)
- Hardcoded-secret regex: skip route-path values (`'/auth/...'`)

P1 — project-type classifier (sprint 2)

- Auto-detect: next-frontend, react-native, django-backend, go-backend, monorepo
- Apply only relevant rule subset per type (no DB rules on pure frontend)
- Per-app reports for monorepos

P2 — framework-aware checks (sprint 3)

- Parse `next.config.{js,ts}` `headers()` for HSTS, CSP, X-Frame-Options
- Scan `app/layout.tsx` + `_document.tsx` for tracking pixels in `<Script>`
- Detect Supabase / Firebase RLS / security rule references

P3 — push coverage above 80%

- SAST integration: Semgrep healthcare ruleset
- Runtime cloud audit: Prowler / Steampipe
- Evidence-path verification (check file paths from interview answers resolve)
- SSL Labs API auto-call for external TLS scan
- Container scan: Trivy / Grype

References & citations

Authoritative sources every rule cites

SOURCE	WHAT IT COVERS
HHS Security Rule	hhs.gov/hipaa/for-professionals/security/laws-regulations
HHS Privacy Rule	hhs.gov/hipaa/for-professionals/privacy/laws-regulations
HHS Breach Notification Rule	hhs.gov/hipaa/for-professionals/breach-notification
NIST 800-66 Rev 2 (Feb 2024)	HIPAA implementation guide
NIST 800-30 Rev 1	Risk assessment methodology
NIST 800-88 Rev 1	Media sanitization
NIST 800-52 Rev 2	TLS configuration
OCR Audit Protocol	The 180+ control checklist OCR actually uses
45 CFR Part 164	The actual federal regulation
HHS Tracking Tech Bulletin (2024)	GA4 / Meta Pixel on patient pages

Internal repository

`github.com/Global-Software-Consulting/hipaa-audit-skill`

Questions?

Live demo available on any project path.
Roadmap items prioritizable by lead direction.

Repo: github.com/Global-Software-Consulting/hipaa-audit-skill
Skill author: Afzal · 2026-06-23